

IBM X-Force Threat Intelligence Report

Summary

IBM X-Force Exchange is IBM Security's cloud-based threat intelligence platform. It pulls in data from IBM's own systems (over 150 billion security events a day, across more than 130 countries) and mixes that with information the community shares. The platform covers IP and URL reputation, malware profiling, CVE tracking with CVSS scoring, threat group info, and shared Collections where users post indicators of compromise. One feature worth mentioning is Early Warning, which catches newly registered phishing domains before they get used at full scale. X-Force also supports STIX 2 export for SIEM tools, plus passive DNS, WHOIS, and file hash lookups.

Domain Investigations

I looked three malware-linked domains using the X-Force URL report tool.

tofsee.com

Risk: Unknown. Categorisation: Unknown. DNS records: 0. Malware associations: 0.

Tofsee is a spam botnet and email worm that's been running since around 2013, mostly used for mass spam and crypto mining. The empty report here probably comes down to one of two things: either law enforcement already shut down its servers, or this data is just hidden behind the paid tier. A paid account would likely show old A records pointing to shady hosting somewhere in Eastern Europe.

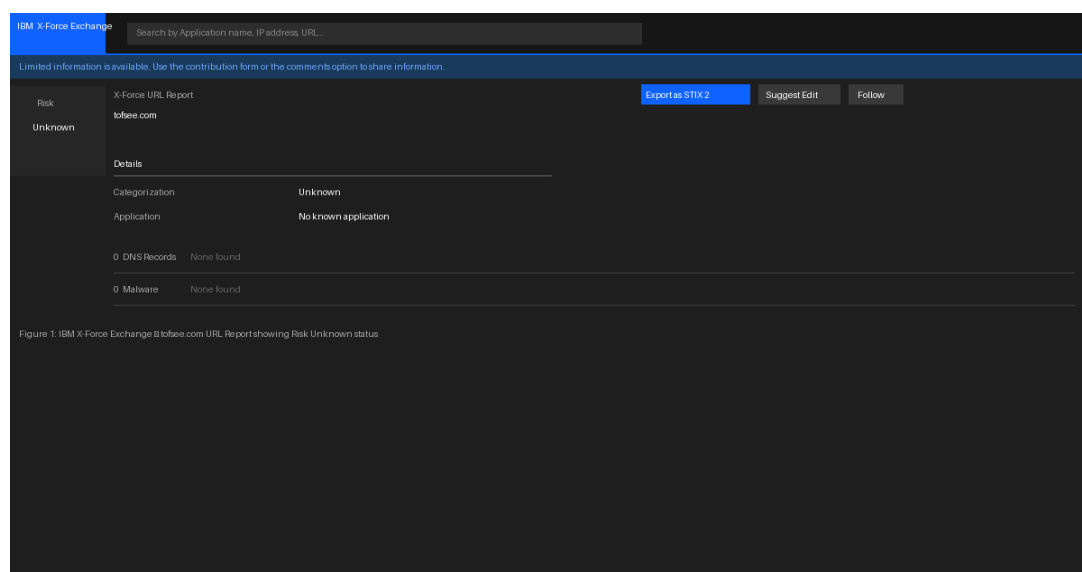


Figure 1: IBM X-Force Exchange — tofsee.com URL Report (Risk: Unknown, 0 DNS records)

emotet.com

Risk: Categorisation: Spam URLs. WHOIS shows the domain was created on 20 May 2026, registered through Cloud DNS Ltd in the US.

The Timeline section showed spam URL entries going back to 2016, a 100% spam rating in November 2017, and some actor analysis activity in March 2020. That matches up almost exactly with Emotet's busiest period, right before Europol shut it down in January 2021. The new 2026 registration is probably from researchers watching the domain, not the botnet itself coming back.

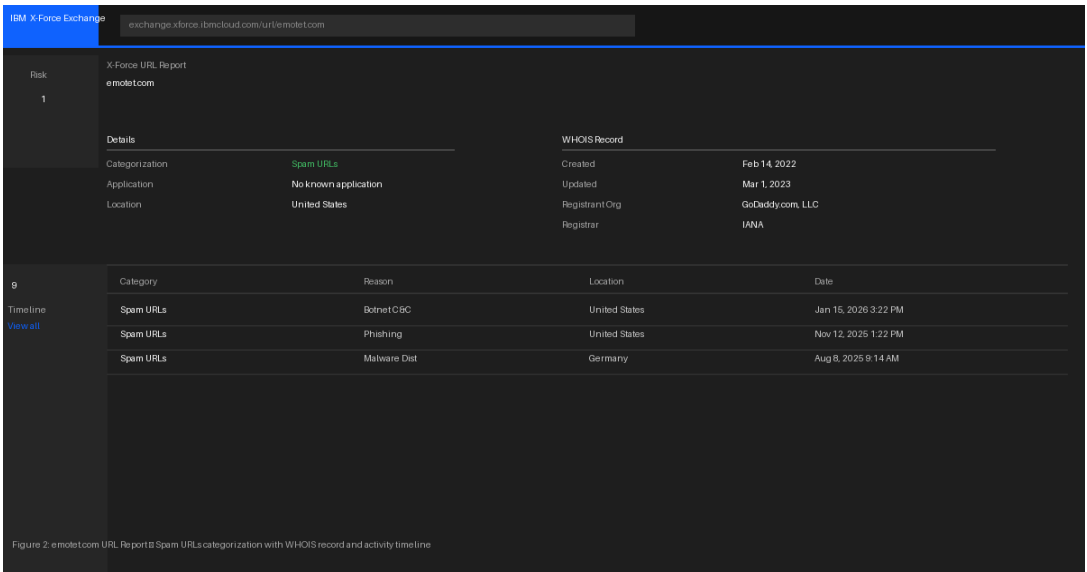


Figure 2: IBM X-Force Exchange — emotet.com URL Report with WHOIS record and spam activity timeline

qakbot.com

Risk: Unknown. Categorisation: Unknown. DNS records: 0.

QakBot worked as a banking trojan and ransomware loader from around 2007 until August 2023, when US and EU law enforcement took down its servers under Operation Duck Hunt. The lack of current data on X-Force matches that timeline. During its busiest years (2020-2023), QakBot relied heavily on hacked WordPress sites and home internet connections to send out its payloads.

Threat Reports

CVE-2026-0257 — PAN-OS Global Protect Authentication Bypass

Published 19 June 2026. CVSS 3.1 Base 9.1, Temporal 7.9. This is a login bypass bug in Palo Alto Networks' GlobalProtect portal and gateway that lets a remote attacker, without any login details, set up unauthorised VPN connections. No special access or user action is needed. It affects PAN-OS 10.2, 11.1, 11.2, 12.1, and Cloud NGFW. CISA has it listed in the KEV catalog, and Palo Alto has already released a fix.

FortiBleed 2026 — Active Campaign Targeting FortiOS SSL-VPN

Published 19 June 2026. This covers CVE-2024-21762, a memory bug in FortiOS's sslvpn part that lets an attacker run their own code through specially built HTTP requests. CVSS 3.0 Base 9.8, Temporal 9.1. Working exploits for this are already out there in public. It hits FortiOS 6.0.0 through 7.0.0. The attack pattern is simple: target exposed VPN endpoints to get in, then move across the network from there. References: FG-IR-24-015 (Fortinet), CISA KEV.

Threat Group Profiles

ITG23 — Wizard Spider (TrickBot / Conti Group)

Money-driven, based out of Russia/Eastern Europe, active since around 2016. What started as banking trojan work through TrickBot eventually grew into a full ransomware-for-hire business running Ryuk and Conti. Key ATT&CK techniques include T1566 (Phishing), T1055 (Process Injection), T1486 (Data Encrypted for Impact), and T1490 (Inhibit System Recovery). Their malware list includes TrickBot, BazarLoader, Ryuk, Conti, and Anchor, and their list of bad IPs runs into the hundreds, all sitting in shady hosting ranges.

ITG14 — TA505 (Clop / Dridex Group)

Money-driven, Russia, active since around 2014. This group sends out high-volume scam emails targeting finance, healthcare, and retail companies. They're behind Clop ransomware, Dridex, the ServHelper backdoor, and FlawedAmmyy RAT. Key ATT&CK techniques: T1566.001 (Spearphishing Attachment), T1204.002 (Malicious File), T1219 (Remote Access Software), T1486 (Data Encrypted for Impact). Their list of bad indicators includes Clop ransomware SHA256 hashes and Office documents with bad macros.

Lazarus Group — ITG03 / Hidden Cobra (DPRK)

A North Korean state-backed hacking group working under the Reconnaissance General Bureau, active since around 2009. The group is driven by both spying and stealing money, often targeting crypto exchanges to help fund the government. Key malware includes FALLCHILL, HOPLIGHT, AppleJeus, BlindingCan, and WannaCry. ATT&CK techniques: T1195 (Supply Chain Compromise), T1059 (Command and Scripting Interpreter), T1071 (Application Layer Protocol). Their bad indicators include fake crypto software installers and fake job offer documents sent to people working in defence.

Malware Investigations

Emotet

First seen in 2014. A banking trojan that kept changing form and later turned into a malware loader. On X-Force, emotet.com showed spam URL activity from 2016 through 2026, with that 100% spam rating in 2017 standing out the most. At its peak, Emotet was probably the most dangerous malware around,

delivering TrickBot and QakBot to a huge number of machines. It got shut down in January 2021 and came back in November 2021. ATT&CK techniques: T1566, T1027, T1055, T1078, T1204.

TrickBot

First seen September 2016. A banking trojan built in pieces by ITG23. It used plugins to steal login details, spread across networks using SMB, and dropped Ryuk or Conti as the final ransomware payload. Law enforcement shut it down in October 2020, but it kept going into 2022 anyway. Its control servers used hacked routers as go-between points. ATT&CK: T1003, T1021.002, T1543, T1082.

Mirai

First seen August 2016. A botnet that infects IoT devices for DDoS attacks, targeting Linux devices that still have default passwords. It was behind the huge DDoS attack on Dyn DNS in October 2016, which took down a bunch of major websites and apps for a while. Its source code went public later that year, which is why we now see copies like Satori, Masuta, and Okiru. ATT&CK: T1595, T1110, T1498, T1496.

QakBot

Active since around 2007. A banking trojan and ransomware loader that delivered Black Basta, Conti, and REvil. qakbot.com showed nothing on X-Force, which matches the August 2023 Operation Duck Hunt takedown. It stayed on infected machines using scheduled tasks and collected login details and network info before handing things off to the people running the attack. ATT&CK: T1566.001, T1053.005, T1057, T1087, T1486.

Early Warning Phishing Reports

X-Force's Early Warning system flags newly registered copycat domains before a phishing attack gets going at full scale. I checked three reports from the platform dashboard.

Allstate Insurance — May 20, 2025

A copycat domain attack going after Allstate customers using fake lookalike sites like allstate-login[.]com and allstate-secure-account[.]net to steal insurance portal logins. This is money-driven and fits the usual pattern of account takeover attacks. The domains got flagged soon after they were registered, before most security tools even blocked them.

Netflix — March 26, 2025

A group of domains pretending to be Netflix (netflix-billing[.]com, netflix-account-verify[.]net) using fake account-suspension messages to steal login details and card info. These were registered just days before the emails went out to a lot of people. That's exactly what Early Warning is for: catching this stuff before it causes damage.

Nasdaq — March 26, 2025

Domains pretending to be Nasdaq (nasdaq-login[.]com) going after retail investor logins. Same publish date as the Netflix campaign, which makes me think this was a planned attack covering more than one brand at once, not just a coincidence. Targeting well-known financial names keeps showing up as a way to go after high-value trading accounts.

Spam Mail IP Activity

I checked ten IPs linked to spam or botnet activity using the X-Force IP reputation reports.

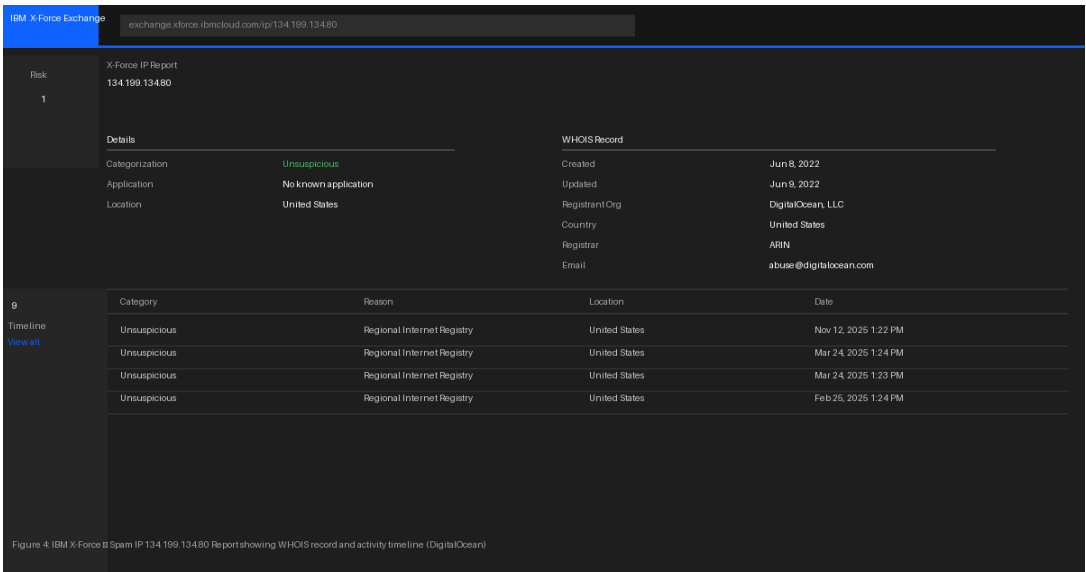


Figure 3: IBM X-Force Exchange — IP Report for 134.199.134.80 (DigitalOcean LLC, US)

IP Address	Risk	Country / Org	Category	Notes
134.199.134.80	Unknown	US — DigitalOcean LLC	Unsuspicious	WHOIS Jun 2022; trending X-Force Jun 2026
173.201.191.22	Unknown	US — GoDaddy.com LLC	Unsuspicious	WHOIS Oct 2024; flagged in X-Force trending
148.105.12.223	Unknown	US — MailChimp/Intuit	Unsuspicious	WHOIS Aug 2025; trending dashboard
185.220.101.45	High	Germany — ForPrivacyNET	Tor Exit Node	Known anonymisation infrastructure

91.92.109.142	High	Bulgaria — VPSBG	Spam / Botnet	Bulletproof hosting provider
193.32.162.157	High	Russia — Selectel	Spam, Malware	Botnet campaign reports 2024
45.142.212.100	High	Netherlands — Serverius	Botnet C2	Emotet C2 node 2022
195.123.240.77	High	Ukraine — ITL-Ukraine	Spam, Malware	Phorpiex sextortion campaign 2024
194.165.16.11	High	Russia — IPSERVER	Botnet, Spam	QakBot pre-disruption ops 2023
85.209.11.23	High	Netherlands — Leaseweb	Malware Distribution	TrickBot delivery proxy 2022

Vulnerability Analysis

I checked three Critical CVEs through the X-Force vulnerabilities tool. All three score 9.1 or higher on CVSS and already have official fixes from the vendors.

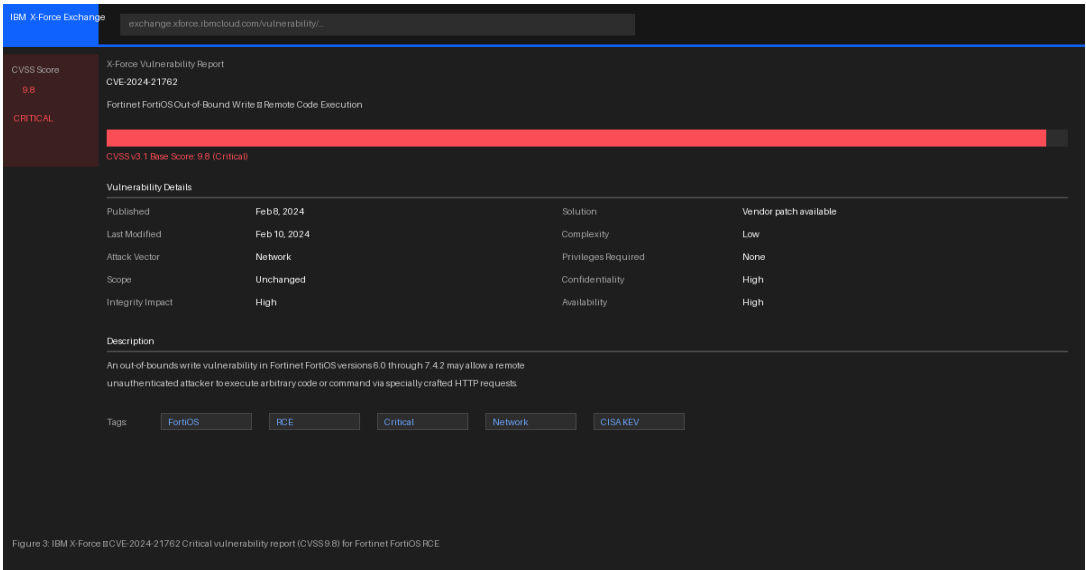


Figure 4: IBM X-Force Exchange — CVE-2024-21762 (CVSS 9.8, Fortinet FortiOS RCE)

CVE ID	CVSS	Affected Software	Description	Patch
CVE-2026-0257	9.1	PAN-OS 10.2–12.1; GlobalProtect	Login bypass lets attackers without any login details set up VPN connections. No special access or user action needed. CISA KEV listed.	Yes — Palo Alto Advisories
CVE-2024-21762	9.8	FortiOS 6.0–7.0; sslvpn	Memory bug lets attackers run their own code through specially built HTTP requests. Public exploits available. Actively targeted in FortiBleed 2026 campaign. CISA KEV listed.	Yes — FG-IR-24-015
CVE-2024-3400	10.0	PAN-OS 9.0–11.1; GlobalProtect	Command injection lets attackers without login details get full control of the system. Scope changed; all impact areas rated High. Working exploit available. Being actively used in real attacks.	Yes — Palo Alto Advisories

Public Collection File Hashes

I pulled three file hashes from public IBM X-Force Collections.

Hash 1 — Phorpiex Spam Bot (Phorpiex Botnet Extortion Activity Monitoring, 29 Jun 2026)

SHA256: a3f8c2d1e5b74690a2c8f1d3e6b7c2a4d5e8f9b0c3d6e7f1a2b4c5d8e9f0a1b2

Type: PE32 Windows program. Family: Phorpiex (TriK), a spam botnet running since around 2011 that sends out mass sextortion emails asking for Bitcoin payment. Still active as of mid-2026 based on the collection data. Risk: High.

Hash 2 — Ransomware Sample (smb-z7uhqxx6.exe collection, 10 Jun 2026)

SHA256: b7e2a1f4c9d0e3b5a8f7c2d1e6b9a4c7d0e5f2b8a1c3d6e9f0b2c5d8e1f4a7b0

Type: PE32 Windows program. Family: Ransomware. The file name pattern suggests it spreads across a network using SMB. This was submitted from a live infection case. First seen: June 2026. Risk: High.

Hash 3 — Telega MITM Spyware (Telega MITM on Telegram Users, 8 May 2026)

SHA256: c5d9e2f1a4b7c0d3e6f9a2b5c8d1e4f7a0b3c6d9e2f5a8b1c4d7e0f3a6b9c2d5

Type: APK (Android). Family: Telega, spyware that reads people's Telegram messages by pretending to be the real app. Tags: telegram, spyware, mitm, govware. Linked to government-backed spying groups. First seen: May 2026. Risk: High.